应急管理制度

中达丰集团有限公司

2025-01-04

文档信息

文档名称编号	应急管理制度（ZDFJT-ITSS-YJGLZD）			
编制单位	中达丰集团有限公司			
文档版本	版本日期	版本说明	作者	审核
V1.0	2025-4-4	发布版本	肖龙莽	吴向阳

目录

应急管理制度 1

中达丰集团有限公司 1

文档信息 2

1. 总则 5

1.1. 目的 5

1.2. 适用范围 5

1.3. 制定依据 5

2. 术语与定义 5

3. 应急管理组织与职责 5

3.1. 应急管理领导小组 5

3.2. 应急执行小组 6

3.3. 支持保障小组 6

4. 风险评估管理机制 6

4.1. 风险评估流程 6

4.2. 资产价值评估 7

4.2.1. 资产分类 7

4.2.2. 资产赋值表 7

4.3. 威胁评估模型 7

4.3.1. 威胁来源分类 7

4.3.2. 威胁频率等级 8

4.4. 风险矩阵与等级划分 8

4.5. 风险评估周期 8

5. 应急事件与应急预案体系 8

5.1. 事件分级标准 8

5.2. 事件分类示例 9

5.3. 应急预案体系 9

5.3.1. 应急预案启动 9

5.3.2. 应急指挥与授权 9

5.3.3. 核心场景处置指引 10

6. 应急响应流程 10

6.1. 总体响应流程 10
6.2. 各阶段详细要求 11
6.2.1. 监测与报告阶段 11
6.2.2. 分析与定级阶段 11
6.2.3. 应急处置阶段 11
6.2.4. 恢复与验证阶段 11
6.2.5. 总结与报告阶段 11
6.2.6. 总结改进阶段 12
7. 应急沟通管理机制 12
7.1. 沟通原则 12
7.2. 信息发布管理 12
7.3. 沟通障碍处理 13
8. 应急保障与资源管理 13
8.1. 人力资源保障 13
8.2. 技术资源保障 13
8.3. 物资与后勤保障 14
9. 应急演练与持续改进 14
9.1. 演练计划 14
9.2. 演练流程 14
9.3. 持续改进机制 14
9.4. 考核指标 15
10. 附则与附件 15
10.1. 制度生效与修订 15
10.2. 附件清单 15
10.3. 相关文件 15

1. 总则

1.1. 目的

为建立健全公司应急响应与风险管理体系，规范应急事件的预防、准备、响应、恢复和改进全过程管理，提升信息系统运维服务的可靠性与连续性，最大限度降低应急事件对客户业务的影响，特制定本制度。

1.2. 适用范围

本制度适用于公司所有运维服务项目

1.3. 制定依据

1. 《信息技术服务运行维护服务能力成熟度模型》（T/CESA 1299-2023）
2. 《信息技术服务运行维护第 1 部分：通用要求》（GB/T 28827.1-2022）
3. 公司质量与安全管理体系文件

2. 术语与定义

术语	定义
应急事件	导致或即将导致运维服务对象运行中断、运行质量降低，以及需要实施重点时段保障的事件。
应急响应	组织为预防、监控、处置和管理应急事件所采取的措施和活动。
风险评估	对信息系统及其相关环境进行资产识别、威胁分析、脆弱性评估，以确定风险等级的过程。
残余风险	在采取安全控制措施后仍无法完全消除的风险。
重点时段保障	在特定时间段内提升服务级别，确保重要活动或业务连续运行的措施。
应急管理小组	由公司指定人员组成的负责应急响应指挥与协调的组织。

3. 应急管理组织与职责

3.1. 应急管理领导小组

组长：副总经理

副组长：质量部经理、研发部经理

主要职责：

1. 审批应急预案与风险评估报告
2. 指挥重大应急事件处置
3. 协调内外部资源支持
4. 评估应急响应效果

3.2. 应急执行小组

组长：运维部经理

成员：运维部成员

主要职责：

1. 执行应急预案
2. 开展事件分析与处置
3. 负责现场指挥与技术恢复
4. 编写事件报告

3.3. 支持保障小组

成员：采购部、人力资源部等运维相关部门

主要职责：

1. 提供物资、交通、法律等支持
2. 负责对外沟通与媒体应对
3. 保障人员调配与后勤服务

4. 风险评估管理机制

4.1. 风险评估流程

准备阶段：明确评估目标、范围、方法与团队

资产识别：识别并分类信息系统资产，评估资产价值

威胁识别：分析可能面临的威胁来源与频率

脆弱性识别：识别技术与管理层面的弱点

风险分析：计算风险值，划分风险等级

风险处置：制定并实施风险控制措施

残余风险评价：评估控制后的剩余风险

4.2. 资产价值评估

4.2.1. 资产分类

类别	示例
数据	数据库、配置文件、业务数据
软件	操作系统、应用系统、中间件
硬件	服务器、网络设备、存储设备
服务	业务系统、网络服务、云服务
人员	关键技术人员、管理员
文档	方案文档、操作手册、合同

4.2.2. 资产赋值表

等级	机密性	完整性	可用性
5（极高）	泄露会造成灾难性影响	破坏会导致业务完全中断	可用性要求≥99.9%
4（高）	泄露会造成严重损害	破坏会导致重大业务影响	允许中断<10分钟
3（中）	泄露会造成一般损害	破坏会造成可修复影响	允许中断<30分钟
2（低）	泄露影响轻微	破坏影响较小	允许中断<60分钟
1（很低）	可公开信息	破坏可忽略	可用性要求低

4.3. 威胁评估模型

4.3.1. 威胁来源分类

环境因素：断电、火灾、水灾、地震等

人为因素（恶意）：黑客攻击、内部破坏、数据窃取

人为因素（非恶意）：操作失误、配置错误、维护不当

技术因素：硬件故障、软件缺陷、网络中断

4.3.2. 威胁频率等级

等级	发生频率	描述
5	≥1次/周	频繁发生，几乎不可避免
4	≥1次/月	较常发生，可能性高
3	>1次/半年	可能发生，有先例
2	≤1次/年	较少发生，可能性低
1	几乎不发生	罕见或例外情况

4.4. 风险矩阵与等级划分

风险值 = 资产价值 × 威胁可能性 × 脆弱性严重程度

风险值范围	风险等级	响应要求
≥12	高（H）	立即处理，优先投入资源
5-11	中（M）	制定计划，限期整改
≤4	低（L）	日常监控，定期复查

4.5. 风险评估周期

全面评估：每年至少一次

专项评估：系统重大变更后

临时评估：发生重大安全事件后

5. 应急事件与应急预案体系

5.1. 事件分级标准

事件等级	综合分值	影响描述	响应时限
I级（重大）	>12分	核心业务完全中断，影响广泛用户	≤15分钟
II级（较大）	5-12分	部分核心业务中断，影响一定范围	≤30分钟
III级（一般）	1-4分	非核心业务中断，影响个别用户	≤60分钟

5.2. 事件分类示例

网络类：网络中断、DDoS 攻击、DNS 故障

系统类：服务器宕机、操作系统崩溃

应用类：业务系统无法访问、数据错误

安全类：病毒爆发、未授权访问、数据泄露

设施类：电力中断、空调故障、火灾水灾

5.3. 应急预案体系

5.3.1. 应急预案启动

公司应急预案体系采用“总体预案+专项预案+现场处置方案”三级结构：

总体预案：即本制度，规定应急组织、流程、保障等通用要求。

专项预案：针对特定类型事件（如核心系统宕机、网络攻击、数据泄露）制定的详细处置程序（参见附件X）。

现场处置方案：针对具体客户或业务系统编制的操作步骤、联络清单与恢复指南。

启动条件：发生Ⅰ级或Ⅱ级事件、客户正式请求、或应急领导小组研判有必要时立即启动。

5.3.2. 应急指挥与授权

事件等级	现场指挥	资源调配权限	关键决策上报
Ⅰ级	副总经理	全部资源	对外发布、重大方案
Ⅱ级	运维部经理	部门内及关联资源	跨部门协调、预算外支出

事件等级	现场指挥	资源调配权限	关键决策上报
III级	运维项目经理	项目组资源	无

5.3.3. 核心场景处置指引

首要目标：30分钟内恢复核心服务。

关键动作：

确认备份系统状态并执行切换。

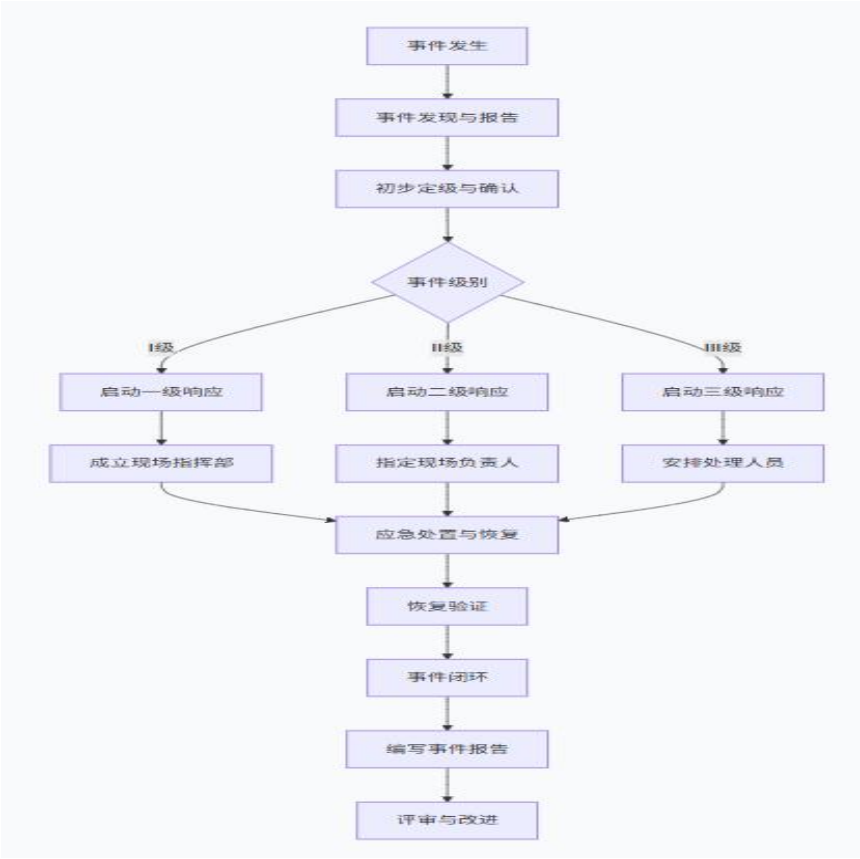
启动数据恢复与一致性检查。

验证核心业务功能。

沟通要求：每15分钟向客户及领导小组通报进展。

6. 应急响应流程

6.1. 总体响应流程



6.2. 各阶段详细要求

6.2.1. 监测与报告阶段

监测方式：7×24 小时监控平台、日志分析、用户反馈

报告渠道：电话、邮件、即时通讯、工单系统

报告内容：事件现象、发生时间、影响范围、初步判断

6.2.2. 分析与定级阶段

成立研判小组：技术、业务、安全人员共同参与

使用定级工具：参考风险矩阵与历史案例

明确响应级别：确定响应团队与资源投入

6.2.3. 应急处置阶段

首要目标：恢复关键业务，控制影响范围

处置策略：

隔离故障点

启用备份系统

实施临时解决方案

记录要求：详细记录处置过程与操作步骤

6.2.4. 恢复与验证阶段

恢复顺序：核心业务→重要业务→一般业务

验证方法：功能测试、性能测试、用户确认

观察期设置：恢复后至少观察 24 小时

6.2.5. 总结与报告阶段

在应急处置结束、系统恢复稳定后，必须进行事件总结，以识别根本原因并推动持续改进。

报告编制：

责任人：运维部经理。

时限：Ⅰ级事件7个工作日内、Ⅱ级事件10个工作日内、Ⅲ级事件15个工作日内，完成《应急事件总结报告》（附件3）。

内容：需包含事件概述、处置过程时间线、根本原因分析（RCA）、影响评估、改进措施计划及经验教训。

根本原因分析(RCA)：

必须使用系统化方法（如5Why分析法、鱼骨图）追溯至管理、流程或技术的根本原因，而非仅停留于表面现象。

评审与归档：

总结报告需提交应急管理领导小组评审。

评审通过后，报告及所有过程记录由质量部统一归档，并将关键知识提炼后录入公司知识库。

6.2.6. 总结改进阶段

根本原因分析：使用 5Why、鱼骨图等方法

制定整改措施：技术优化、流程改进、培训加强

更新知识库：将处理经验纳入应急知识库

7. 应急沟通管理机制

7.1. 沟通原则

及时性原则：第一时间通报关键信息

准确性原则：确保信息真实、准确、完整

适度性原则：根据受众提供适宜信息

一致性原则：统一口径，避免信息矛盾

7.2. 信息发布管理

发布渠道：邮件、公告、会议、电话会议

发布内容：事件状态、影响范围、预计恢复时间、处理进展

发布时机：

初始通报：事件确认后 30 分钟内

进展通报：每 2-4 小时（根据事件级别）

总结通报：事件解决后 24 小时内

7.3. 沟通障碍处理

常见障碍：信息不对称、职责不清、沟通渠道不畅

解决方案：

1. 建立明确的沟通路线图
2. 指定专职沟通协调员
3. 使用标准化沟通模板
4. 定期进行沟通演练

8. 应急保障与资源管理

8.1. 人力资源保障

应急团队组建：明确各角色 AB 岗

技能培训：每季度至少一次应急培训

人员调度机制：建立快速响应人员库

8.2. 技术资源保障

资源类型	配置要求	检查频率
备用设备	关键设备有热备或冷备	每月一次
备份系统	核心系统有异地备份	每周一次
应急工具	专用应急工具包	每季度一次
文档资料	应急预案、配置文档	更新即检查

8.3. 物资与后勤保障

应急物资清单：包括硬件、软件、耗材、文档

供应商快速通道：建立优先支持机制

后勤支持：交通、食宿、通讯等保障

9. 应急演练与持续改进

9.1. 演练计划

演练类型	频率	参与范围	目标
桌面推演	每季度	核心团队	熟悉流程
专项演练	每半年	相关团队	检验专项能力
全面演练	每年	全员参与	检验整体响应

9.2. 演练流程

1. 策划阶段：制定演练方案，明确场景与目标
2. 准备阶段：准备环境、数据、人员分工
3. 执行阶段：按计划开展演练并记录
4. 评估阶段：评估演练效果，识别问题
5. 改进阶段：制定改进措施并跟踪

9.3. 持续改进机制

建立完整的“计划-执行-检查-处理”（PDCA）改进闭环：

P (计划)：根据事件总结报告和演练评估报告，制定具体的改进措施，明确责任人与完成时限。

D (执行)：责任人实施改进措施，如流程优化、系统加固、培训开展等。

C (检查)：质量部负责跟踪验证改进措施的完成情况与效果，通过后续事件、演练或专项审计进行检验。

A (处理)：将行之有效的措施标准化，纳入制度或预案；未达标的措施转入下一个PDCA循环。

9.4. 考核指标

序号	衡量指标	指标计算说明	考核频次	目标值
1	应急演练次数	应急演练次数	半年	≥1次

10. 附则与附件

10.1. 制度生效与修订

本制度自发布之日起生效，由运维服务中心负责解释。重大修订需经应急管理领导小组审批。

10.2. 附件清单

附件 1：应急联系人清单模板

附件 2：应急事件报告模板

附件 3：风险评估表模板

附件 4：应急演练记录表

附件 5：应急物资清单模板

10.3. 相关文件

《信息安全管理制度》

《业务连续性计划》

《变更管理流程》

《问题管理流程》